Security incident report

Section 1: Identify the network protocol involved in the incident
The network protocols identified during the investigation are DNS (Domain Name System), HTTP (Hypertext Transfer Protocol), and TCP (Transmission Control Protocol). DNS is used to translate domain names, such as yummyrecipesforme.com and greatrecipesforme.com, into IP addresses. HTTP is used by the browser to request and receive web pages and to communicate with the websites involved in the incident. TCP provides reliable communication between the browser and the web server. These protocols appear in the tcpdump logs during the DNS lookups and HTTP requests made before and after the malware download. The logs show that the browser first connects to yummyrecipesforme.com and then makes another DNS request and HTTP connection to greatrecipesforme.com after the malicious file is executed.

Section 2: Document the incident
The website yummyrecipesforme.com was hacked by a former employee. The attacker tried several passwords until finding the administrator's default password. After logging in, they changed the website's code to make visitors download a fake browser update with malware. They also changed the admin password, locking out the website owner. A few hours later, customers reported that the website asked them to download a file to view free recipes. After opening the file, they were redirected to greatrecipesforme.com, a fake website. Their computers also started running more slowly.

Investigation and evidence:

The security team used tcpdump in a sandbox to check the website's network traffic.

The logs showed that:

1. The browser used DNS to find the IP address of yummyrecipesforme.com.
2. The browser sent an HTTP request to the website.
3. The website asked the visitor to download a file.
4. After the file was opened, the browser used DNS to find the IP address of greatrecipesforme.com.
5. The browser then sent an HTTP request to the fake website.

The security team checked the website's code and found malicious JavaScript. They also checked the downloaded file and confirmed that it redirected visitors to the fake website.

Impact:

The attack exposed customers to malware and made their computers slower. It could also put their personal information at risk. The attack affected the company's website and prevented the owner from accessing the admin panel.

Sources of evidence:

- Tcpdump logs.
- Customer complaints.
- Website source code.
- The downloaded file.
- The senior analyst's findings.

Section 3: Recommend one remediation for brute force attacks
The organization should limit the number of consecutive failed login attempts allowed for administrative accounts. After a defined number of unsuccessful attempts, the system should temporarily lock the account or introduce an increasing delay before allowing another attempt. Security alerts should also be

generated when repeated failed logins are detected.

This measure is effective because brute-force attacks rely on trying many passwords until the correct one is found. Limiting login attempts makes it significantly more difficult for an attacker to guess a password successfully within a short period.

The organization should also ensure that all default passwords are replaced with strong, unique passwords. These measures would reduce the risk of unauthorized administrative access and help prevent similar incidents in the future.